

Studiengänge: BA Cyber Security Management, BA Cyber Security Management dual,
BA W Cyber Security Management Teilzeit

Realistische Übungsklausur - Variante A

BCSM 402 - Business Continuity Management

Sommersemester 2026 | Prof. Dr. Gael Pentang

Name	
Matrikel-Nr.	
Hiermit erkläre ich, dass ich prüfungsfähig bin.	

- Erlaubte Hilfsmittel: Stifte, Textmarker, Taschenrechner.
- Die Unterlage umfasst insgesamt 14 Seiten (einschließlich Deckblatt) mit 8 Aufgaben: 1 Single-Choice-Aufgabe, 5 Freitextaufgaben und einer Case Study mit 2 Aufgaben.
- Zum Bestehen der Klausur sind insgesamt mindestens 61 Punkte erforderlich.
- Wenn Ihnen der vorhandene Platz nicht ausreicht, können Sie die Rückseiten benutzen. Zusätzliche Blätter sind mit Name und Matrikel-Nr. zu beschriften.
- Schreiben Sie nicht mit Bleistift. Markieren Sie bei Single-Choice-Fragen genau eine Antwortmöglichkeit.

	erreichte Punktzahl
Prüfungsabschnitt 1: 20 Single-Choice-Fragen	40
Aufgabe 1	
Prüfungsabschnitt 2: Freitextaufgaben	40
Aufgabe 2	
Aufgabe 3	
Aufgabe 4	
Aufgabe 5	
Aufgabe 6	
Prüfungsabschnitt 3: Case Study	40
Aufgabe 7	
Aufgabe 8	
Summe	120

Hinweis: Diese Übungsklausur wurde anhand des Original-Deckblatts, der Probeklausur, der Themen-Eingrenzung, der Vorlesungsfolien und der Übungen erstellt. Sie ist keine offizielle Klausur.

Prüfungsabschnitt 1

Aufgabe 1 - Single-Choice-Fragen (20 x 2 = 40 Punkte)

Bitte markieren Sie genau eine Antwortmöglichkeit. Nur jeweils eine Antwort ist richtig. Werden mehrere Antworten markiert, wird die Frage mit 0 Punkten bewertet.

1. Welche drei Dimensionen gehören zur Scope-Definition eines BCMS?
 - a. Organisatorisch, geografisch/physisch und logisch/Wertschöpfung
 - b. Strategisch, taktisch und operativ
 - c. Präventiv, detektiv und reaktiv
 - d. Intern, extern und regulatorisch
 - e. Keine von a. bis d.
2. Welche Aussage zu Ausschlüssen aus dem BCMS-Scope trifft zu?
 - a. Ausschlüsse sind ohne Begründung zulässig, wenn sie Kosten sparen.
 - b. Ausschlüsse müssen begründet werden und dürfen kritische Funktionen nicht gefährden.
 - c. Externe Dienstleister dürfen grundsätzlich nicht in Abhängigkeiten betrachtet werden.
 - d. Der Scope darf nur die gesamte Organisation umfassen.
 - e. Alle von a. bis d.
3. Welche Aussage beschreibt ISO 22301 und BSI-Standard 200-4 korrekt?
 - a. ISO 22301 beschreibt vor allem das WIE und ist nicht zertifizierbar.
 - b. BSI 200-4 ist eine internationale Zertifizierungsnorm.
 - c. ISO 22301 definiert Anforderungen; BSI 200-4 bietet eine praxisnahe Methodik mit Stufenmodell.
 - d. Beide Standards zertifizieren ausschließlich Personen.
 - e. Keine von a. bis d.
4. Was kennzeichnet das Reaktiv-BCMS nach BSI 200-4?
 - a. Vollständiger PDCA-Zyklus und ISO-Konformität
 - b. Schnelle rudimentäre Reaktionsfähigkeit mit Fokus auf Alarmierung, Sofortmaßnahmen und BAO
 - c. Vollständige BIA für alle Prozesse im Scope
 - d. Ausschließlicher Fokus auf interne Audits
 - e. Alles von a. bis d.

5. Welche Verantwortung der Institutionsleitung ist nicht delegierbar?
 - a. Gesamtverantwortung für das BCMS
 - b. Pflege jeder einzelnen Kontaktliste
 - c. Moderation jedes BIA-Workshops
 - d. Durchführung jedes technischen Wiederanlauftests
 - e. Keine von a. bis d.
6. Welche Aussage zum BC-Beauftragten (BCB) trifft zu?
 - a. Er leitet in jeder Krise zwingend den Krisenstab.
 - b. Er ist zentrale Ansprechperson, Methodenwächter und berichtet idealerweise direkt an die Institutionsleitung.
 - c. Er ist ausschließlich für IT-Backups zuständig.
 - d. Er darf keine Notfallpläne bereitstellen.
 - e. Alle von a. bis d.
7. Wofür steht das A in RASCI?
 - a. Approved
 - b. Accountable - rechenschaftspflichtig
 - c. Assigned
 - d. Audited
 - e. Keine von a. bis d.
8. Welche Grundregel gilt bei der RASCI-Zuordnung?
 - a. Pro Aufgabe soll es nur ein A geben.
 - b. Pro Aufgabe muss es mindestens zwei R geben.
 - c. C und I dürfen nie gleichzeitig vorkommen.
 - d. S ist immer die Institutionsleitung.
 - e. Alle von a. bis d.

9. Welche Aussage grenzt BIA und BCM-Risikoanalyse korrekt voneinander ab?
- a. Die BIA untersucht Ursachen; die Risikoanalyse nur Auswirkungen.
 - b. Die BIA betrachtet Auswirkungen von Ausfällen; die Risikoanalyse betrachtet Ursachen, Gefährdungen und Eintrittswahrscheinlichkeiten.
 - c. Beide Verfahren sind identisch.
 - d. Die Risikoanalyse muss immer vor der BIA erfolgen.
 - e. Keine von a. bis d.
10. Welche Beziehung muss fachlich konsistent sein?
- a. RTO ist kleiner oder gleich MTPD.
 - b. RPO ist immer größer als MTPD.
 - c. MBCO ist eine Zeitangabe.
 - d. MTPD ist immer kleiner als RTO.
 - e. Alle von a. bis d.
11. Was beschreibt der RPO?
- a. Die maximale Dauer bis zum Notbetrieb
 - b. Den maximal zulässigen Datenverlust
 - c. Das minimale Notbetriebsniveau
 - d. Die Eintrittswahrscheinlichkeit eines Risikos
 - e. Keine von a. bis d.
12. Was beschreibt der MBCO?
- a. Die maximal tolerierbare Ausfallzeit
 - b. Den maximal zulässigen Datenverlust
 - c. Das Mindestniveau, auf dem der Geschäftsbetrieb im Notbetrieb fortgeführt werden soll
 - d. Die Zeit bis zum Abschluss eines Audits
 - e. Keine von a. bis d.

13. Wie lautet die typische Reihenfolge der Risikoanalyse?
- Identifizieren, Analysieren, Evaluieren, Behandeln
 - Evaluieren, Identifizieren, Behandeln, Analysieren
 - Analysieren, Behandeln, Identifizieren, Evaluieren
 - Behandeln, Evaluieren, Analysieren, Identifizieren
 - Keine von a. bis d.
14. Welche Gruppe enthält ausschließlich Risikobehandlungsoptionen?
- Vermeiden, vermindern, übertragen, akzeptieren
 - Erkennen, melden, prüfen, dokumentieren
 - Planen, umsetzen, auditieren, zertifizieren
 - Priorisieren, eskalieren, kommunizieren, archivieren
 - Keine von a. bis d.
15. Welche Zuordnung ist richtig?
- BIA = Wer und wann; Strategie = Was; BCP = Wie
 - BIA = Was; Strategie = Wie; Notfallplanung/BCP = Wer und wann
 - BIA = Warum; Strategie = Wer; BCP = Wie viel
 - BIA = Wie; Strategie = Wann; BCP = Warum
 - Keine von a. bis d.
16. Welche Aussage unterscheidet Notfall und Krise korrekt?
- Beim Notfall existieren geeignete Pläne oder sie können angepasst werden; in der Krise greifen Pläne nicht oder nur unzureichend.
 - Eine Krise wird immer in der AAO bewältigt.
 - Ein Notfall betrifft nie zeitkritische Prozesse.
 - Bei einer Krise ist keine BAO erforderlich.
 - Alle von a. bis d.

17. Welcher Schritt folgt bei FOR-DEC unmittelbar auf Options?
- a. Execution
 - b. Risks & Benefits
 - c. Check
 - d. Decision
 - e. Facts
18. Was ist der Schwerpunkt eines Stage-I-Audits?
- a. Vor-Ort-Begehung und Interviews zur gelebten Praxis
 - b. Dokumentenreview und Prüfung der grundsätzlichen Eignung des BCMS
 - c. Ausschließliche Prüfung von IT-Systemen
 - d. Erteilung des Zertifikats ohne weitere Prüfung
 - e. Keine von a. bis d.
19. Aus welchen drei Elementen besteht eine belastbare Nichtkonformität?
- a. Anforderung, tatsächliche Abweichung und objektiver Nachweis
 - b. Meinung, Empfehlung und Frist
 - c. Risiko, Kosten und Nutzen
 - d. Scope, RTO und RPO
 - e. Keine von a. bis d.
20. Welche Aussage trifft auf ITSCM zu?
- a. ITSCM ersetzt das gesamte BCM.
 - b. ITSCM fokussiert Technologie und Infrastruktur und unterstützt die Wiederherstellung kritischer IT-Komponenten.
 - c. ITSCM betrachtet ausschließlich Pressearbeit.
 - d. ITSCM ist unabhängig von BIA-Ergebnissen.
 - e. Alle von a. bis d.

Prüfungsabschnitt 2: Freitextaufgaben

Aufgaben 2 bis 6 - insgesamt 40 Punkte

Antworten Sie fachlich präzise und strukturiert. Stichpunkte sind zulässig, sofern die Zusammenhänge klar erkennbar sind.

Aufgabe 2 (8 Punkte) - Dokumentenhierarchie eines BCMS

Beschreiben Sie eine typische Dokumentenhierarchie eines BCMS. Ordnen Sie mindestens acht geeignete Dokumente den PDCA-Phasen Plan, Do, Check und Act zu.

Aufgabe 3 (8 Punkte) - Stufenmodell des BSI 200-4

Erläutern Sie die drei Stufen Reaktiv-BCMS, Aufbau-BCMS und Standard-BCMS. Gehen Sie jeweils auf Ziel, Methodik bzw. Umfang und den Bezug zur ISO-22301-Zertifizierung ein.

Aufgabe 4 (8 Punkte) - BIA und kritische Parameter

Grenzen Sie Business Impact Analyse und BCM-Risikoanalyse voneinander ab. Definieren Sie anschließend MTPD, RTO, RPO und MBCO und stellen Sie deren Beziehungen dar.

Aufgabe 5 (8 Punkte) - BCM-Governance und RASCI

Beschreiben Sie die Rollen der Institutionsleitung, des BC-Beauftragten und der dezentralen BC-Koordinatoren. Ordnen Sie für die Erstellung und Freigabe einer BCM-Leitlinie sinnvolle RASCI-Rollen zu.

Aufgabe 6 (8 Punkte) - Auditarten und Zertifizierungsstufen

Erläutern Sie 1st-, 2nd- und 3rd-Party-Audits. Stellen Sie anschließend die Unterschiede zwischen Stage I und Stage II eines Zertifizierungsaudits einschließlich typischer Auditmethoden dar.

Prüfungsabschnitt 3: Case Study

Fallstudie New Generation Autos (NGA)

Die New Generation Autos AG (NGA) produziert in Brandenburg PKW. Der Mutterkonzern fordert ein BCMS für Produktion und Marketing. Produktion, Materialplanung, Einkauf, Qualitätssicherung, Marketing sowie die hierfür erforderliche IT sind im Scope; Verkauf und Auslieferung wurden begründet ausgeschlossen.

NGA produziert 6 PKW pro Stunde. Ein PKW hat einen Gegenwert von 20.000 EUR. Die Produktion läuft 8 Stunden pro Tag und 5 Tage pro Woche. Fällt ein Produktionsschritt vollständig aus, steht die gesamte Produktion.

Die Zulieferer BuCa und ACT liefern jeweils 50 % des Produktionsmaterials. Nach einem Hochwasser fällt BuCa voraussichtlich 10 Tage aus. Der Lagerbestand reicht für einen Produktionstag. ACT kann ab dem dritten Tag insgesamt 70 % des normalen Materialbedarfs liefern. Weitere Zulieferer sind nicht vertraglich gebunden.

Die Produktions-IT wird durch IT-4all betrieben. Im Vertrag ist eine Wiederanlaufzeit von 8 Stunden vereinbart. Ein vollständiger Wiederherstellungstest liegt 18 Monate zurück. Für den Montageprozess existiert derzeit kein abgestimmter RPO.

Aufgabe 7 (20 Punkte) - Scope und Business Impact Analyse

Bearbeiten Sie die folgenden Teilaufgaben auf Grundlage des Falles:

- a) Nennen Sie vier Prozesse bzw. Ressourcen, die im Scope liegen, sowie zwei relevante externe Stakeholder oder Abhängigkeiten. **(6 P.)**
- b) Berechnen Sie den direkten finanziellen Produktionsausfall bei 4 Stunden vollständigem Stillstand und bei zwei vollständigen Produktionstagen. **(4 P.)**
- c) Schlagen Sie für den Montageprozess plausible Werte für MTPD, RTO, RPO und MBCO vor. Begründen Sie Ihre Werte und achten Sie auf eine konsistente Beziehung der Parameter. **(8 P.)**
- d) Nennen Sie zwei weitere Schadenskategorien neben dem finanziellen Schaden. **(2 P.)**

Aufgabe 8 (20 Punkte) - Risikobewertung und Business-Continuity-Strategie

Bearbeiten Sie die folgenden Teilaufgaben:

- a) Formulieren Sie für den Zuliefererausfall und den Ausfall der Produktions-IT jeweils Bedrohung, Schwachstelle, Risiko und potenzielle Auswirkung. **(8 P.)**
- b) Ordnen Sie beide Risiken begründet einer Risikostufe zu. Eine nachvollziehbare qualitative Einordnung genügt. **(4 P.)**
- c) Nennen Sie insgesamt zwei präventive und zwei reaktive Maßnahmen zur Behandlung der Risiken. **(4 P.)**
- d) Nennen Sie vier Mindestinhalte, die in einem geeigneten Notfall- bzw. Response-Plan dokumentiert sein sollten. **(4 P.)**